

Data Access, Privacy, and AI Usage Policy

Policy ID	POL-SEC-001	Version	2.0
Status	SUPERSEDED	Effective Date	2025-01-01
Review / End Date	2025-12-31	Supersedes	1.0
Policy Owner	Information Security and Data Governance	Business Unit	ENTERPRISE
Jurisdiction	GLOBAL	Classification	INTERNAL CONFIDENTIAL
Access Scope	ROLE_BASED	Synthetic Document	YES

Document control note: When multiple versions exist, the applicable version is the version whose effective-date range contains the business date and whose status is ACTIVE. A higher version number with a future effective date must not be used for current-date decisions.

1. Policy Objective

This synthetic policy is designed to support development and testing of a production-grade asset-servicing AI copilot. It contains realistic document-control metadata, version changes, effective dates, operational rules, escalation requirements, and evidence expectations.

2. Purpose and Scope

Defines requirements for confidential data, customer information, AI-assisted processing, logging, masking, and controlled system access.

Control requirement: decisions must be traceable to an authorized source, user permissions must be validated before restricted information is returned, and exceptions to policy require a reason, approver, timestamp, and evidence reference.

3. Sensitive Data Handling

Direct identifiers and restricted fields must be masked or tokenized before use in non-essential prompts, traces, analytics, and lower environments.

Control requirement: decisions must be traceable to an authorized source, user permissions must be validated before restricted information is returned, and exceptions to policy require a reason, approver, timestamp, and evidence reference.

4. AI and Tool Access

AI agents must use governed interfaces, least privilege, approved tool schemas, input validation, authorization checks, and immutable audit logs.

Control requirement: decisions must be traceable to an authorized source, user permissions must be validated before restricted information is returned, and exceptions to policy require a reason, approver, timestamp, and evidence reference.

5. Monitoring and Retention

Security events, model interactions, tool calls, and policy decisions must be logged according to approved retention and access requirements.

Control requirement: decisions must be traceable to an authorized source, user permissions must be validated before restricted information is returned, and exceptions to policy require a reason, approver, timestamp, and evidence reference.

Current Version-Specific Rules

Control	Requirement in v2.0
PII masking	Required outside approved operational systems
Privileged access review	Semi-annual
AI trace redaction	Required for direct identifiers
Audit retention	6 years

Operational Decision Rules

Use current and authoritative source-system data for live operational status. Document policy content must not be treated as a substitute for live trade, exception, break, case, or corporate-action state.

Where policy evidence conflicts, route the case to Policy Validation and prefer the applicable effective version. Do not silently merge contradictory versions.

High-risk or low-confidence decisions require human escalation. The AI copilot may summarize evidence and recommend next steps but must preserve source references and decision traceability.

Cached responses must be scoped by authorization and policy version. Policy activation or supersession must invalidate related cached answers.

Roles and Responsibilities

Role	Responsibility
Operations Analyst	Investigates assigned items, validates evidence, records actions, and escalates when required.
Team Lead / Checker	Reviews sensitive or high-value actions, validates policy use, and approves controlled overrides.
Policy Control	Maintains policy versions, effective dates, interpretation guidance, and formal exceptions.
Technology / AI Platform	Maintains access controls, audit trails, approved integrations, monitoring, and retrieval quality controls.
Information Security	Defines data handling, masking, secrets, privileged access, incident response, and monitoring requirements.

Audit and Evidence Requirements

- Record the policy ID, policy version, page or section reference, query timestamp, user identity, and access scope used in the decision.
- For live operational lookups, record the MCP tool name, approved parameters, authorization result, response timestamp, and source-system reference.
- PII and confidential fields must be masked in prompts and traces unless explicitly required and permitted for the operational task.
- Observability records must not become an uncontrolled secondary store of customer-sensitive data.

Examples and Test Scenarios

Scenario	Expected Policy Behavior
User asks about an exception and an older policy is effective. A newer policy is effective. A newer policy is effective.	Use the effective ACME version for the business date; cite the current section and suppress superseded g
A v4 policy exists but becomes effective in the future.	Do not use v4 for today's decision; v3 remains applicable until the v4 effective date.
User lacks permission for a restricted account.	Return an authorization-safe response; do not expose restricted customer or account details.
Semantic cache contains an answer created in the past.	Indicate and bypass the cache and regenerate using the current applicable policy.
Live operational status differs from a historical status.	Use live governance data for status; use policy only for rules and required actions.

End of controlled synthetic document. This file is intentionally structured to test OCR/layout extraction, document-aware chunking, metadata enrichment, version-aware retrieval, citations, and policy validation.